Universiteit van Amsterdam
Amsterdam Business School

Cybersecurity/AI auditing

Prof. dr. Edo Roos Lindgreen, Jeroen van Beek MSc

Agenda

How to audit cybersecurity and AI?

1. Recap
2. Deep dive: cybersecurity auditing
3. Deep dive: AI auditing

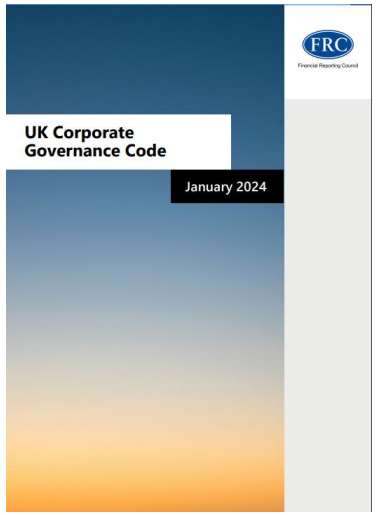
4. Post mortem incident analysis

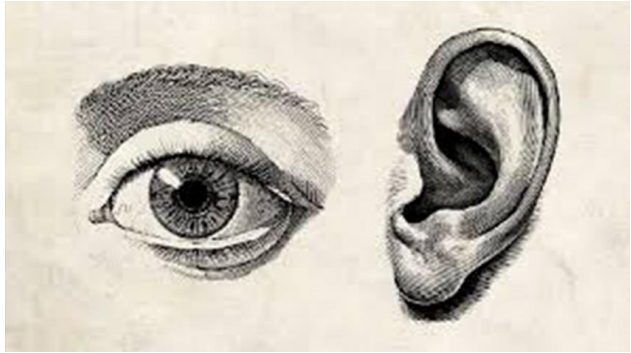
Recap

WHAT – IT-audit is the professional and independent evaluation of risks associated with the use of information technology and the effectiveness of controls to mitigate these risks.

WHY – Board is responsible for strategy execution and risk management. Supervisory board (non-executive) has three roles: supervision, employer, advisor. Board needs independent information on risks and risk management. Audit fulfills this role and reports to audit committee in supervisory board. Issues that keep the board awake are IT-related: cyber and digital disruption.

HOW – IT-audit consists of four key phases. 1. Preparation: risk analysis, planning, scoping. 2. Field work: data analysis, interviews, desk research, etc. 3. Reporting: minutes, draft report, audi alteram partem ("hear the other side"), management response, final report, presentation. 4. Follow-up.





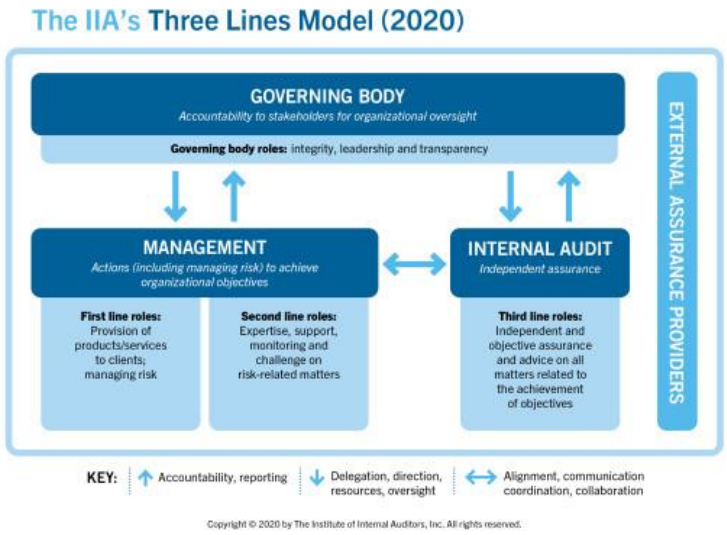
Deep dive: cybersecurity auditing

Cybersecurity audit variants

- **Audit (reasonable assurance):** Formal check against a specific standard, with a conclusion (pass/fail)
- **Assessment (limited assurance):** Broader review of security posture; reporting findings; more consultative.
- **Penetration testing (limited assurance):** Simulating an attack to find technical vulnerabilities.
- **Vulnerability scanning (limited assurance):** Automated search for known flaws (only one part of an audit).

IIA Three Lines model

- **First Line:** Operational Management (Owns and manages risk).
- **Second Line:** Risk Management & Compliance functions (Oversees risk).
- **Third Line:** Internal Audit (Provides independent assurance).
- **Fourth line:** External audit, regulators and external bodies.



Cybersecurity audit standards: ISO/IEC 27000 family

97 (draft) standards for information security

ISO 27001

- Information Security Management System
- Context, leadership, planning, support, operation, evaluation, improvement

ISO 27002

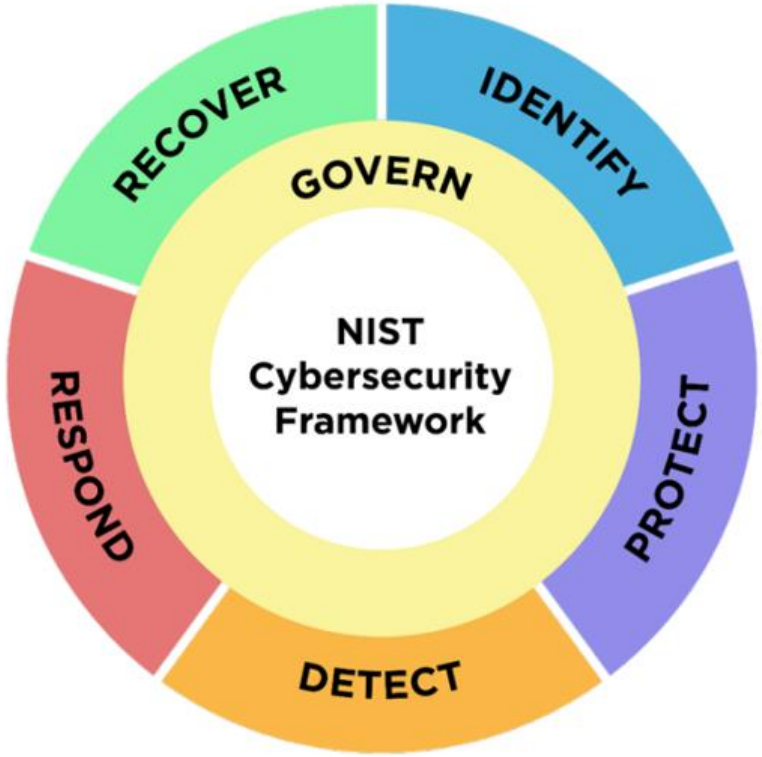
- Information security controls
- See next slide

ISO/IEC 27002

1. **Information Security Policies**
2. **Organization of Information Security**
3. **Human Resource Security**
4. **Asset Management**
5. **Access Control**
6. **Cryptography**
7. **Physical and environmental security**
8. **Operation Security -** Procedures and responsibilities, Protection from malware, Backup, Logging and monitoring, Control of operational software, Technical vulnerability management and Information systems audit coordination
9. **Communication security** - Network security management and Information transfer
10. **System acquisition, development and maintenance** - Security requirements of information systems, Security in development and support processes and Test data
11. **Supplier relationships** - Information security in supplier relationships and Supplier service delivery management
12. **Information security incident management** - Management of information security incidents and improvements
13. Information security aspects of **business continuity management** - Information security continuity and Redundancies
14. **Compliance** - Compliance with legal and contractual requirements and Information security reviews

Cybersecurity audit standards: NIST framework

Function	Category	Category Identifier
Govern (GV)	Organizational Context	GV.OC
	Risk Management Strategy	GV.RM
	Cybersecurity Supply Chain Risk Management	GV.SC
	Roles, Responsibilities, and Authorities	GV.RR
	Policies, Processes, and Procedures	GV.PO
	Oversight	GV.OV
Identify (ID)	Asset Management	ID.AM
	Risk Assessment	ID.RA
	Improvement	ID.IM
Protect (PR)	Identity Management, Authentication, and Access Control	PR.AA
	Awareness and Training	PR.AT
	Data Security	PR.DS
	Platform Security	PR.PS
	Technology Infrastructure Resilience	PR.IR
Detect (DE)	Continuous Monitoring	DE.CM
	Adverse Event Analysis	DE.AE
Respond (RS)	Incident Management	RS.MA
	Incident Analysis	RS.AN
	Incident Response Reporting and Communication	RS.CO
	Incident Mitigation	RS.MI
Recover (RC)	Incident Recovery Plan Execution	RC.RP
	Incident Recovery Communication	RC.CO



Deep dive: AI auditing

AI is a super fast moving target

- AI advancements are incredible
- Not always easy to separate hype and fantasy from reality
- AI adoption at all levels: corporate AI versus “shadow AI”

Working definition : The independent evaluation of AI systems to ensure they perform as intended, are fair, and comply with regulations.

Business case for AI auditing

- Mitigating **risks**: reputation, liability, financial risk, compliance
- Strategic: trustworthy AI is a **competitive advantage**

IT-audit versus AI-audit

IT-audit	AI-audit
Logical controls	Statistical validity
Correctness and completeness	Fairness and non-bias
Static / stable software	Self-learning system
Periodic	Continuous
Known skills	Unknown skills
Clear standards	No clear standards

EU AI Act

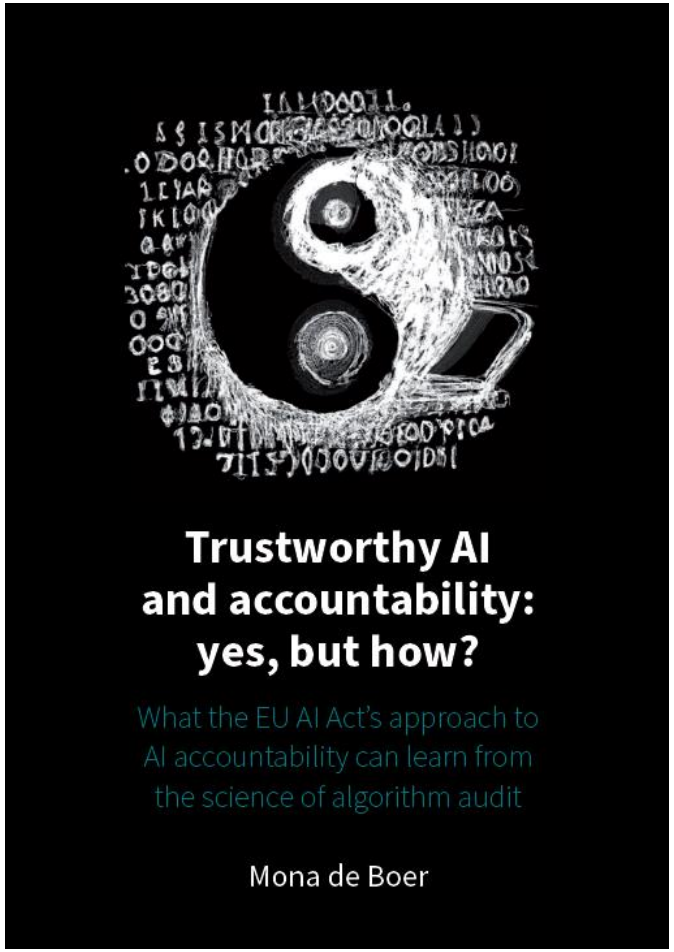
European Commission

- In effect per August 2024

- Risk-based
  - Unacceptable risk: banned (social credit scoring, mass surveillance)
  - **High risk: stringent requirements**
  - Limited risk: notification (chatbots)
  - Minimal risk: no intervention (recommender systems)

National Supervisory Authority

https://ec.europa.eu/commission/presscorner/detail/en/ip_21_1682



What is high risk AI?

- Critical **infrastructures** (e.g. transport), that could put the life and health of citizens at risk;
- Educational or vocational **training**, that may determine the access to education and professional course of someone's life (e.g. scoring of exams);
- **Safety** components of products (e.g. AI application in robot-assisted surgery);
- **Employment**, workers management and access to self-employment (e.g. CV-sorting software for recruitment);
- **Essential** private and public services (e.g. credit scoring denying citizens opportunity to obtain a loan);
- **Law enforcement** that may interfere with people's fundamental rights (e.g. evaluation of the reliability of evidence);
- **Migration**, asylum and border control management (e.g. verification of authenticity of travel documents);
- Administration of justice and **democratic processes** (e.g. applying the law to a concrete set of facts).

Requirements for high-risk AI

- Adequate risk assessment and mitigation systems
- High quality of the datasets feeding the system to minimise risks and discriminatory outcomes
- Logging of activity to ensure traceability of results
- Detailed documentation providing all information necessary on the system and its purpose for authorities to assess its compliance
- Clear and adequate information to the user
- High level of robustness, security and accuracy
- **Appropriate human oversight measures to minimise risk**

Points of attention in AI audit

- **Governance**: asset management, model owner, human in the loop, oversight?
- **Data**: data lineage, data quality, representation, privacy?
- **Model training**: algorithm choice, overfitting, finetuning/hyperparameters, documentation?
- **Model testing**: red teaming, stress testing, adversarial testing
- **Monitoring post-deployment:**
  - Self-learning
  - Model drift
  - Retraining triggers
  - Fairness and bias
  - Explainability
  - Hallucinations, toxic output
  - IP and privacy infringements

Evalueer via **https://app.evalytics.nl/#**

zja-176